

PORTFOLIO SIMULATION • FICTIONAL ORGANIZATION

Azure Finance VM Security Assessment

Northstar Ridge Financial Services | Cloud Security Case Study

AZURE SECURITY POSTURE • SECURE REDESIGN • INCIDENT RESILIENCE

Organization	Northstar Ridge Financial Services (fictional)
Assessment Type	Azure Cloud Security Posture / Secure Redesign
Analyst	Ryan Bryant
Primary Asset	NFG-FIN-APP01 - Critical Finance Application VM
Security Model	Least privilege Segmentation JIT/PIM Centralized monitoring
Scope	Identity, privileged access, VM/network security, monitoring, recovery

Portfolio Note

This case study documents a fictional Azure security assessment and secure redesign exercise. No real organization, Azure tenant, production workload, or live customer data was assessed or modified. The project demonstrates cloud-security reasoning, architecture analysis, risk prioritization, and stakeholder communication.

1. Document Purpose and Control

This case study consolidates the Azure fundamentals, analyst findings, and secure-redesign decisions developed during the Northstar Ridge cloud-security exercise. The objective is to demonstrate how a cybersecurity analyst can move from basic Azure platform concepts into a structured security assessment of a critical finance workload.

Field	Value
Document owner	Cybersecurity / Cloud Security Portfolio
Status	Completed portfolio case study
Assessment basis	Simulated Azure environment and analyst-developed security recommendations
Primary stakeholders	Security, IT, Finance, cloud operations, executive leadership
Decision objective	Reduce exposure, lateral movement, standing privilege, visibility gaps, and recovery uncertainty

1.1. Contents

- 2. Executive Summary
- 3. Scenario and Current-State Environment
- 4. Assessment Process
- 5. Findings and Risk Register
- 6. Identity and Privileged Access Redesign
- 7. Network Security and Lateral-Movement Controls
- 8. Monitoring, Detection, and Third-Party Visibility
- 9. Backup, Recovery, and Resilience
- 10. Target-State Architecture and Validation
- 11. Portfolio Outcome and Skills Demonstrated
- Appendix A. Consolidated Azure Finding Sheet

2. Executive Summary

Northstar Ridge Financial Services relies on NFG-FIN-APP01, a business-critical Azure virtual machine that supports an internal Finance application. The simulated assessment identified a high-risk combination of public management exposure, persistent privileged access, weak network isolation, delayed patching, incomplete centralized telemetry, and unvalidated recovery capability.

The most significant immediate issue was direct Internet exposure of RDP (TCP/3389) to Any source through a public IP. For a critical Finance workload, this creates an unnecessary administrative attack path. The redesign removes direct public administration, places the workload in a protected Finance subnet, and uses Azure Bastion and Just-in-Time access for controlled management.

Executive Risk Statement

The Finance workload has useful baseline controls such as disk encryption, daily backup, and Microsoft Defender, but the current configuration leaves excessive administrative and network exposure. A compromised credential, adjacent workload, or unpatched vulnerability could create a wider incident because privileged access, segmentation, logging, and recovery validation are not yet mature.

2.1. Risk Distribution

Critical	High	Moderate	Low
1	5	0	0

2.2. Immediate Priorities

- Remove the public RDP path and require Azure Bastion / JIT for administrative access.
- Enforce Entra ID, MFA, Conditional Access, least-privilege RBAC, and PIM for privileged roles.
- Place the Finance VM in a dedicated protected subnet with explicit NSG paths.
- Restore patch compliance, enable Defender tamper protection, and reduce local administrator exposure.
- Centralize Windows, identity, firewall/NSG, Defender, and supported vendor telemetry in Log Analytics / Sentinel.
- Test restoration and failover procedures against defined recovery objectives.

3. Scenario and Current-State Environment

The assessment focuses on NFG-FIN-APP01, a Windows-based Azure VM hosting a critical internal Finance application over HTTPS. The exercise evaluates the workload as part of a broader Azure architecture rather than treating the VM as an isolated endpoint.

Control Area	Current State	Security Observation
Public exposure	Public IP attached; TCP/3389 allowed from Any	Direct Internet-reachable management path
Administrative access	IT administrators connect directly using RDP	No secure brokered path; broader exposure
Network placement	Shares subnet with three general-purpose application servers	Expanded lateral-movement opportunity
Patching	47 days since last successful patch cycle	Known-vulnerability exposure may be elevated
Endpoint protection	Microsoft Defender installed; tamper protection disabled	Protection can be weakened after compromise
Local privilege	Two local administrator accounts	Persistent local privilege requires review
Logging	Windows logs remain local	Investigation and correlation visibility is limited
Network telemetry	No centralized NSG/network monitoring	Allowed/denied traffic patterns are not centrally visible
Backup	Daily Azure Backup enabled	Positive control, but recovery has not been validated
Encryption	OS disk encrypted	Useful baseline data-protection control

Assessment Boundary

The exercise evaluates security architecture and control design. It does not claim that an Azure tenant was deployed, scanned, exploited, or modified. Recommendations reflect a simulated analyst review of the stated configuration.

4. Assessment Process

The assessment process was intentionally structured to follow the same sequence a security analyst could use when reviewing a cloud workload: understand the business service, identify exposure, validate identity and privilege, analyze network trust paths, assess host protections, evaluate telemetry, and verify recovery.

Step	Process	Analyst Question	Security Outcome
1	Establish criticality and scope	What business service does this workload support?	Prioritize controls based on Finance impact
2	Map exposure and trust boundaries	What can reach the VM from the Internet or adjacent subnets?	Identify unnecessary attack paths
3	Review identity and authorization	Who can sign in, and what can they do?	Apply Entra ID, MFA, Conditional Access, RBAC
4	Review privileged access	Are admin rights permanent or time-bound?	Use PIM, JIT, approval, justification, and audit trails
5	Review segmentation and traffic rules	Can a compromised system move directly to Finance or data resources?	Dedicated subnet and deny-by-default NSG paths
6	Review endpoint posture	Is the VM patched and protected from security-tool tampering?	Patch compliance and Defender hardening
7	Review monitoring and detection	Can analysts reconstruct identity, host, and network activity?	Centralize logs in Log Analytics and Sentinel
8	Review recovery	Can the service actually be restored within business expectations?	Test backup, restoration, RTO/RPO, and failover
9	Prioritize and communicate	Which conditions create the greatest likelihood and impact?	Risk-ranked findings and implementation plan

4.1. Control-Layer Model

Defense in Depth

Entra ID authentication -> MFA / Conditional Access -> RBAC authorization -> PIM elevation when required -> Bastion/JIT administrative path -> Azure Firewall / NSGs / subnet segmentation -> Defender endpoint protection -> Azure Monitor / Log Analytics / Sentinel visibility -> Backup and disaster-recovery validation.

5. Findings and Risk Register

Six material findings were documented. The first is assessed as Critical because the management interface is directly reachable from the public Internet. The remaining findings are High because they meaningfully increase the likelihood or impact of credential abuse, lateral movement, persistence, missed detection, or failed recovery.

ID	Finding	Risk	Evidence / Condition	Recommended Control
AZ-FIN-01	Public management exposure	Critical	Public IP attached; RDP/3389 allowed from Any source	Remove direct public RDP. Use Bastion and JIT; restrict management sources.
AZ-FIN-02	Standing privileged access	High	Broad/persistent administrative access; PIM not fully enforced	Use least-privilege RBAC + PIM activation, MFA, approval, justification, ticket reference, and expiration.
AZ-FIN-03	Insufficient network isolation	High	Finance VM shares subnet with general-purpose servers	Move to dedicated Finance subnet; allow only approved app, admin, monitoring, backup, and data paths.
AZ-FIN-04	Endpoint hardening gaps	High	47-day patch gap; Defender tamper protection off; two local admins	Restore patch compliance, enable tamper protection, review Defender findings, minimize/secure local admins.
AZ-FIN-05	Incomplete centralized visibility	High	Windows logs local; network telemetry incomplete; vendor activity not fully centralized	Send identity, Windows, firewall/NSG, Defender, and supported vendor telemetry to Log Analytics/Sentinel.
AZ-FIN-06	Unvalidated recovery	High	Daily backup configured but full restoration/failover not proven	Test restoration, define RTO/RPO, verify dependencies, and conduct recurring recovery exercises.

5.1. Risk Rationale

The ratings are qualitative portfolio-assessment ratings rather than production risk scores. They are based on the stated exposure, workload criticality, plausible attack paths, and the degree to which compensating controls are missing or unvalidated.

6. Identity and Privileged Access Redesign

The redesigned access model separates authentication, authorization, and privilege elevation. Microsoft Entra ID establishes the identity; MFA and Conditional Access determine whether the sign-in should proceed; Azure RBAC determines what the identity can do at a defined scope; and PIM provides temporary elevation when privileged access is justified.

Control	Target-State Requirement
Microsoft Entra ID	Use centralized identity for administrators, Finance users, and approved vendor identities.
MFA	Require strong authentication for privileged access and sensitive Finance resources.
Conditional Access	Restrict access based on user, role, device compliance, sign-in risk, location/network context, and application sensitivity.
Azure RBAC	Assign only required permissions and scope; avoid subscription-wide access when a resource-group or resource scope is sufficient.
PIM	Make powerful roles Eligible rather than permanently Active. Require justification, ticket reference, MFA, approval where appropriate, and automatic expiration.
Separate admin identity	Use privileged accounts only for administrative work; do not use the same identity for routine email/web activity.
Emergency access	Maintain controlled break-glass capability for tenant recovery and monitor its use.

Privilege Principle

A user may be authorized to perform administrative work without carrying that privilege continuously. PIM converts standing privilege into a temporary, auditable capability that is activated only for an approved purpose.

7. Network Security and Lateral-Movement Controls

The network redesign assumes that a workload or user account may eventually be compromised. The objective is therefore not only to block initial access, but also to reduce the attacker's ability to move from one system to another.

Trust Path	Target-State Policy
Internet -> NFG-FIN-APP01	No direct RDP/SSH. Finance application access only through explicitly approved application paths.
Admin -> Finance VM	Use Azure Bastion and JIT; restrict management to approved identities, devices, and time windows.
General app subnet -> Finance subnet	Deny by default. Permit only documented application dependencies.
Finance VM -> Data tier	Allow only required database service/port to approved database destination.
Finance VM -> Monitoring	Allow outbound telemetry to approved monitoring/security services.
Finance VM -> Backup	Allow only approved backup/recovery service communication.
East-west traffic	Deny unnecessary peer-to-peer communication and log suspicious or denied movement attempts.

7.1. Validation Scenario

If an adjacent general-purpose application server is compromised, the attacker should not inherit a direct route to NFG-FIN-APP01 simply because both workloads exist in the same Azure environment. The protected Finance subnet and restrictive NSGs should block unauthorized east-west access, while Azure Firewall, Defender, and centralized telemetry provide additional prevention and visibility.

Fictional portfolio simulation | Prepared by Ryan Bryant | September 2026 | Page 9

8. Monitoring, Detection, and Third-Party Visibility

The target state centralizes security-relevant telemetry so analysts can correlate events across identity, endpoints, network controls, Azure control-plane actions, and approved third-party access. Microsoft Sentinel serves as the SIEM/SOAR layer, while Azure Monitor / Log Analytics provide centralized collection and querying.

Telemetry Source	Security Use
Microsoft Entra ID	Sign-ins, risky authentication, MFA/Conditional Access outcomes, privileged role activity
Windows / VM logs	Authentication, privilege use, service/process activity, system events
Microsoft Defender	Endpoint/cloud detections, tamper alerts, security recommendations, suspicious behavior
Azure Activity Logs	Resource changes, administrative actions, control-plane operations
NSG / Firewall telemetry	Allowed/denied network activity, suspicious connection attempts, unexpected east-west traffic
Bastion / JIT / PIM records	Who requested privileged access, why, for how long, and what was approved
Third-party/vendor telemetry	Approved vendor authentication and activity where supported by connectors or logging integrations
Microsoft Sentinel	Correlation, incident creation, investigation, hunting, dashboards, and response playbooks

8.1. Example Analyst Workflow

- Sentinel identifies a suspicious sign-in or unusual administrative action.
- The analyst correlates Entra ID, VM, Defender, and network telemetry in Log Analytics / Sentinel.
- The analyst validates whether the event matches approved PIM/JIT activity and an existing ticket.
- If unauthorized, the response may include identity containment, session revocation, VM isolation, or rule changes.
- The incident is reviewed for lessons learned, detection tuning, and policy/process improvements.

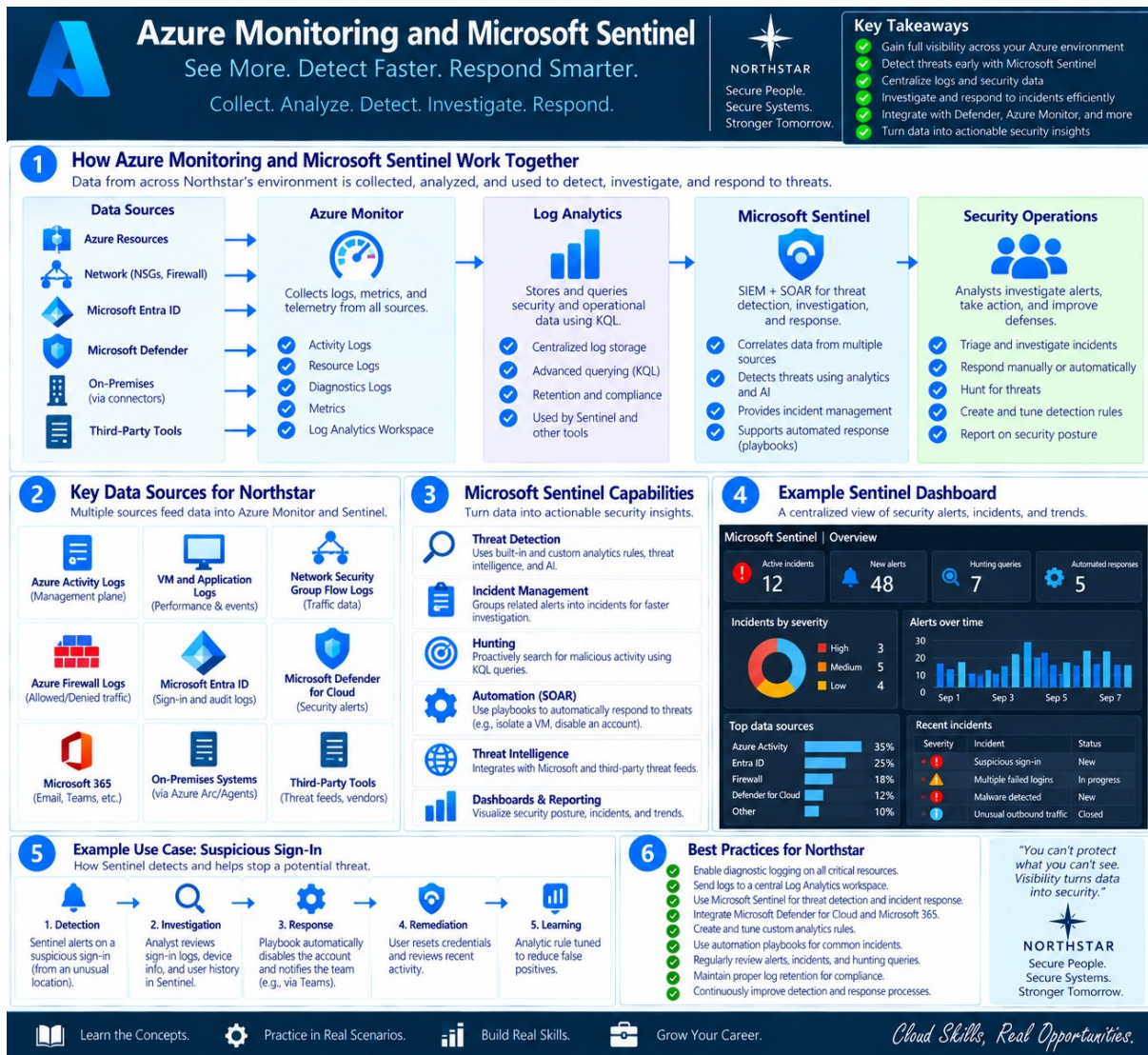


Figure 2. Centralized telemetry supports detection, investigation, threat hunting, and response.

9. Backup, Recovery, and Resilience

Daily Azure Backup is a positive control, but backup configuration alone does not demonstrate recoverability. The assessment therefore distinguishes between 'a backup exists' and 'the critical Finance service has been restored successfully within business requirements.'

Recovery Requirement	Validation Activity
Backup integrity	Confirm backup jobs complete successfully and protected data is readable.
Full restoration	Restore the VM/application into an isolated recovery location and verify service functionality.
RTO	Define the maximum acceptable outage duration for the Finance application and measure restoration performance.
RPO	Define the maximum acceptable data-loss window and confirm backup/replication frequency can meet it.
Dependencies	Validate identity, DNS, networking, database, secrets/certificates, monitoring, and application dependencies.
Regional resilience	Determine whether a secondary region / Site Recovery design is required for the stated business impact.
Exercises	Repeat recovery tests on a defined schedule and document issues, owners, remediation, and retest results.
Recovery Principle	
A backup is evidence of data protection. A successful, measured restore is evidence of recoverability.	

10. Target-State Architecture and Validation

The secure redesign combines the identity, privilege, network, monitoring, endpoint, and recovery controls into one layered Azure security architecture. The goal is to make compromise harder, reduce the blast radius when compromise occurs, improve analyst visibility, and ensure the critical service can recover.

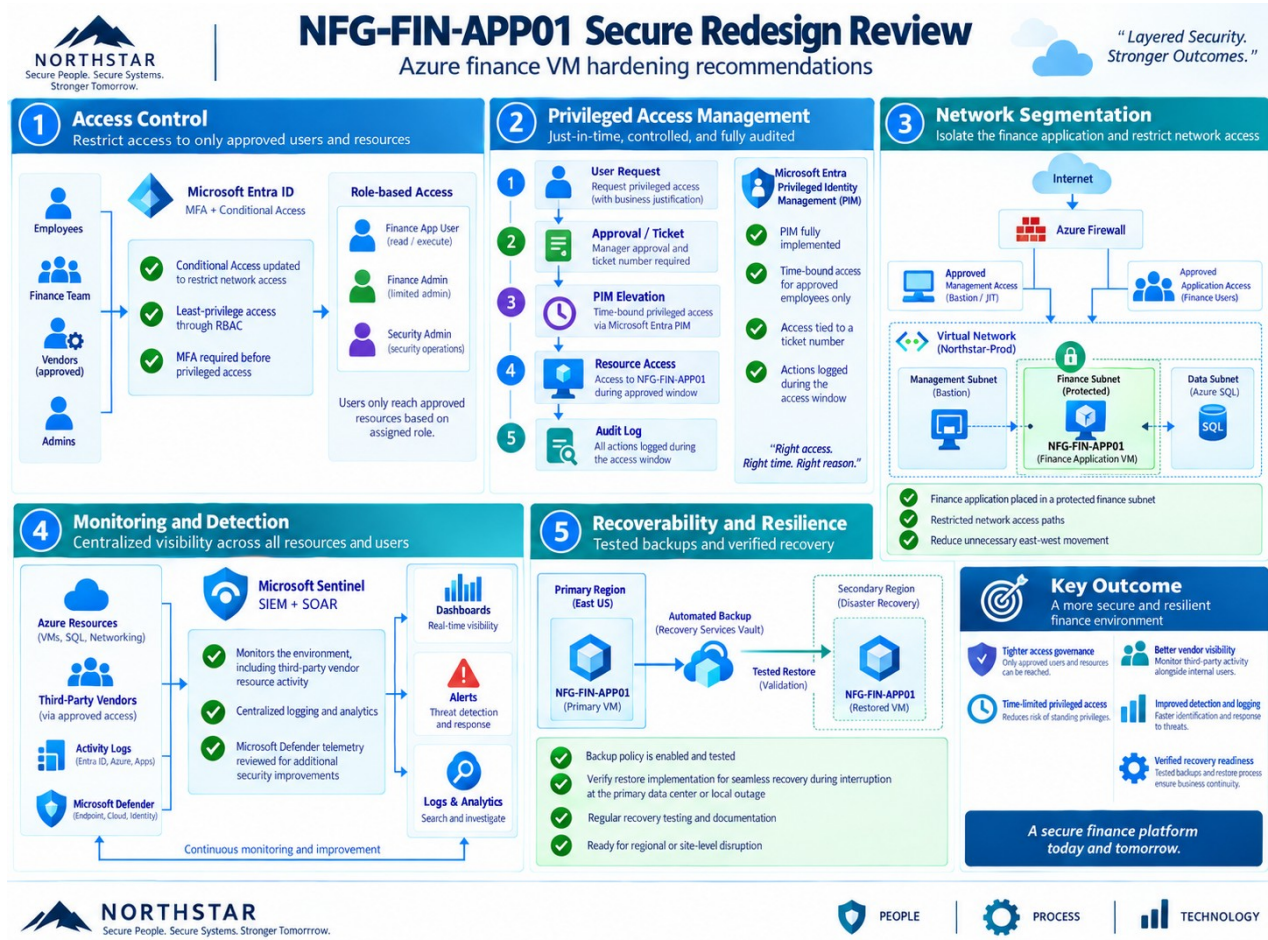


Figure 3. Target-state secure redesign for NFG-FIN-APP01.

10.1. Expected Security Outcomes

- No always-open public RDP/SSH path to the Finance VM.
- Privileged actions are time-bound, approved, justified, and logged.
- The Finance workload is isolated from general-purpose systems through subnet segmentation and explicit NSG paths.
- Defender, Azure Monitor / Log Analytics, and Sentinel provide centralized security visibility.
- Third-party activity is incorporated into monitoring where supported.
- Backup and disaster-recovery procedures are validated through restoration testing.

11. Portfolio Outcome and Skills Demonstrated

This project began as an Azure fundamentals learning exercise and progressed into a structured cloud-security assessment. The final deliverable demonstrates the ability to connect individual Azure services into a coherent defense-in-depth architecture rather than treating each service as an isolated tool.

Skill Area	Evidence Demonstrated
Azure fundamentals	Service models, regions, availability zones, resource groups, VNets, subnets, public/private access concepts
Cloud network security	NSGs, Azure Firewall, segmentation, traffic-path analysis, Bastion, JIT, lateral-movement reduction
Cloud IAM	Microsoft Entra ID, MFA, Conditional Access, RBAC scopes, PIM, least privilege, separation of admin accounts
Monitoring and detection	Azure Monitor, Log Analytics, Defender, Sentinel, telemetry correlation, analyst investigation workflow
Recovery and resilience	Azure Backup, restoration validation, RTO/RPO reasoning, regional recovery considerations
Risk communication	Risk-ranked findings, remediation priorities, architecture narrative, executive-friendly reporting

11.1. Final Analyst Conclusion

Conclusion

The original configuration provided useful baseline protection but exposed a critical Finance workload to unnecessary management and lateral-movement risk. The proposed redesign applies least privilege, temporary privilege elevation, segmented trust, centralized monitoring, endpoint hardening, and verified recovery. Together, these controls produce a stronger and more defensible Azure security posture while preserving operational access for approved users and administrators.

11.2. Portfolio Positioning

This document should be presented as a fictional cloud-security architecture and assessment case study. It demonstrates analyst reasoning and design decisions rather than hands-on administration of a production Azure tenant.

Appendix A - Consolidated Azure Finding Sheet

The following one-page finding sheet summarizes the six primary risks, recommended controls, target-state access flow, and assessment conclusion.

NORTHSTAR Fictional Training Environment		Azure Finance VM Security Assessment - Finding Sheet		Prepared by Ryan Bryant Cybersecurity Analyst Portfolio Exercise September 16, 2026	
Assessment Objective Scope: Critical Azure finance application VM NFG-FIN-APP01. The review focuses on external exposure, privileged administration, network segmentation, endpoint hardening, centralized monitoring, third-party visibility, and recovery readiness.			Overall Risk CRITICAL - Current State Driven primarily by unrestricted public RDP exposure and weak privileged-access controls.		Recommended Architecture Target State: Private Finance subnet + restrictive NSGs + Azure Firewall + Bastion/JIT + Entra ID/MFA/Conditional Access + RBAC/PIM + Defender + Log Analytics/Sentinel + validated backups/failover.
Key Findings and Remediation Priorities					
ID	Finding	Risk	Professional Assessment	Recommended Control	
AZ-FIN-01	Public management exposure VM has a public IP and RDP/3389 is allowed from Any source.	CRITICAL	Direct Internet-reachable RDP creates an unnecessary administrative attack path to a critical Finance system.	Remove direct public RDP exposure. Use Azure Bastion for routine administration and JIT access for exceptional RDP/SSH needs.	
AZ-FIN-02	Privileged access is not sufficiently time-bound Administrative access is broader and more persistent than necessary.	HIGH	Standing privilege increases the impact of credential compromise and makes privileged activity harder to constrain.	Use Entra ID + MFA + Conditional Access, enforce least-privilege RBAC, and implement PIM activation with justification, approval, ticket reference, time limit, and audit logging.	
AZ-FIN-03	Insufficient network isolation Finance VM shares a subnet with general-purpose application servers.	HIGH	Shared placement increases lateral-movement opportunities if another server in the subnet is compromised.	Move the Finance VM to a dedicated protected subnet. Apply NSGs that allow only approved application, management, monitoring, and backup paths.	
AZ-FIN-04	Endpoint protection and patching gaps 47 days since successful patching; Defender tamper protection is disabled; two local admin accounts exist.	HIGH	Unpatched vulnerabilities, modifiable security tooling, and persistent local admin credentials increase compromise and persistence risk.	Restore patch compliance, enable tamper protection, review Defender findings, minimize local administrators, and rotate/protect any retained emergency local credential.	
AZ-FIN-05	Incomplete centralized visibility Windows logs are local; network-flow monitoring is incomplete; third-party activity is not fully centralized.	HIGH	Security teams may miss suspicious authentication, privilege use, lateral movement, or vendor activity across the environment.	Send Windows, Entra ID, Azure Activity, NSG/firewall, Defender, and supported third-party/vendor telemetry to Log Analytics and Microsoft Sentinel for correlation and alerting.	
AZ-FIN-06	Recovery capability is configured but not validated Daily Azure Backup is enabled, but restoration and failover readiness have not been proven.	HIGH	A backup that has not been restored successfully is not sufficient evidence that the critical service can recover within business requirements.	Test full restoration, document RTO/RPO, verify application dependencies, validate secondary-region or site-level recovery procedures, and repeat recovery testing on a defined schedule.	
Target-State Access Flow Entra ID authentication -> MFA / Conditional Access -> RBAC authorization -> PIM elevation when required -> Bastion/JIT administrative path -> segmented Finance subnet -> Defender + Log Analytics + Sentinel monitoring.			Assessment Conclusion: The redesign reduces the Finance VM's external attack surface, limits lateral movement, removes unnecessary standing privilege, improves analyst visibility, and converts backup configuration into verified recovery capability. The result is a layered, auditable, and more resilient Azure security architecture.		

Appendix A. Consolidated Azure Finance VM Security Assessment Finding Sheet.